STRIDE Threat Model Analysis Report Template

Student name: Humphrey Wanjala
Date: 02/07/2026

1. System Overview and Scope

Description of the System/Application:
(Briefly describe the purpose and functionality of the system.)

AutoDrive Manufacturing provides a connected and autonomous vehicle platform that enables cloud-based telemetry collection, remote diagnostics, and over-the-air (OTA) software updates to enhance safety and vehicle performance. The platform uses the AWS cloud infrastructure and enables vehicle authentication, data exchange between vehicles and the cloud, remote firmware updates, and a REST API enabling secure access to diagnostics and requests for software updates by authorized service centers and partners. Given that the platform controls physical operations of the vehicles using firmware updates and ADAS, a breach of security may lead to safety incidents, not only to data breaches. It raises the significance of security beyond common enterprise IT systems and aligns with the ISO/SAE 21434 (Road Vehicles, Cybersecurity Engineering).

Why is security important to AutoDrive? (1) Vehicles are physically distributed endpoints, internet connected and impossible to patch instantaneously, (2) OTA updates have direct control over the vehicle firmware and safety-critical operations, (3) telemetry data contains personally identifiable and location data, protected by regulations, and (4) API surface exposes vehicle functionality to third parties.

Key Components in Scope:
(List the critical components of the system that will be analyzed, e.g., authentication, data storage, communication channels.)

Vehicle Authentication System — certificate-based vehicle authentication, MFA for employees, and password recovery flow.

Telemetry System for Vehicle Data Collection and Management — collection, encryption, storage, and access to vehicle diagnostic and localization data.

Over-the-Air (OTA) Update System — packaging of firmware, signing, pushing updates, and rolling back to previous firmware version.

Secure Communication System — the communication channel for the update notifications, emergency notifications, and security warnings from vehicles to the cloud.

API for Partner Integration — REST API secured with OAuth/API keys that is used by service centers and partners.

Scope of Analysis:
Entire system analyzed
Specific features analyzed *(Specify: e.g., login process, messaging, file uploads, APIs, etc.)*

Comprehensive system analysis – this document examines all five of the above-mentioned components, namely, authentication, data processing, OTA, messaging, and external APIs access, in light of the recently experienced incidents (credential stuffing, API misuse, firmware manipulation, and DoS) by AutoDrive.

2. System Components Breakdown

List of Major Components:
(Break down the system into its primary components and their functions.)

Component	Description
Vehicle Authentication System	Authenticates vehicles to the cloud platform using digital certificates and secure key exchange; enforces MFA for personnel accessing remote diagnostics; provides a self-service password reset for fleet-service users.
Vehicle Telemetry and Data Management	Collects continuous engine diagnostics, GPS location, and performance metrics from each vehicle; encrypts data at rest (AES-256) and in transit (TLS 1.2/1.3); restricts access to authorized engineers and fleet managers.
OTA Software Update System	Packages and remotely deploys firmware to vehicles; validates firmware integrity via cryptographic signatures before installation; supports rollback if an update fails or is found to be malicious.
Secure Messaging and Communication System	Carries update notifications, emergency alerts, and security warnings between vehicles and AutoDrive's cloud over an encrypted channel; logs and monitors anomalous message patterns.

API for Third-Party Integration	REST API used by authorized service centers and partners to retrieve diagnostics, pull security logs/version details, and request software updates; protected by OAuth authentication, API keys, and rate limiting.

(Add or remove table rows as necessary.)

3. STRIDE Threat Identification

For each system component, identify potential threats based on the STRIDE model.

STRIDE Categories Reference:

- **Spoofing** – Can an attacker pretend to be someone else?
- **Tampering** – Can an attacker modify data or code?
- **Repudiation** – Can a user deny performing an action?
- **Information Disclosure** – Can sensitive data be exposed?
- **Denial of Service (DoS)** – Can an attacker disrupt system availability?
- **Elevation of Privilege** – Can an attacker gain unauthorized access?

STRIDE Threat Matrix

(Identify one or more threats for each component.)

Component	STRIDE Category	Threat Description
Vehicle Authentication System	Spoofing	An attacker leverages credential-stuffing (matching the recent failed-login pattern) combined with session hijacking to impersonate a fleet manager and bypass MFA.
Vehicle Telemetry and Data Management	Tampering	An attacker intercepts or gains write access to stored telemetry and alters diagnostic, location, or performance data to mask malicious activity or falsify vehicle condition.
Vehicle Authentication System	Repudiation	A fleet-service user denies having performed a password reset or accessed diagnostics because reset actions are not

		tied to a verifiable, tamper-evident audit log.
Vehicle Authentication System	Information Disclosure	The password reset workflow reveals whether a submitted email/username is registered, enabling account enumeration by an attacker.
Vehicle Authentication System	Denial of Service	Repeated automated login attempts (credential stuffing) overwhelm the authentication service, causing the traffic spikes already observed and degrading vehicle connectivity for legitimate users.
Vehicle Authentication System	Elevation of Privilege	An attacker exploits a flaw in MFA enrollment or session management to escalate from a standard fleet-service account to an administrative role.

(Add or remove table rows as necessary.)

4. Risk Assessment and Impact

Assess each identified threat based on **Likelihood** and **Impact** to prioritize risks.

Threat	**STRIDE Category**	**Likelihood (L/M/H)**	**Impact (L/M/H)**	**Overall Risk Level**
API probing exposes diagnostics/security logs beyond scope	Information Disclosure	High	High	critical
Broken access control lets a partner escalate to firmware-update requests	Elevation of Privilege	Medium	High	high

Emergency alert / warning message tampered in transit	Tampering	Low	high	Medium
Firmware tampered in transit or via compromised signing key	Tampering	Medium	High	critical
Service-center account escalates OTA scope to unauthorized vehicles	Elevation of Privilege	Medium	High	high

(L = Low, M = Medium, H = High)

(Add or remove table rows as necessary.)

5. Mitigation Strategies

Propose security controls to mitigate each identified threat.

Threat	STRIDE Category	Mitigation Strategy
Stolen/cloned vehicle certificate impersonation	Spoofing	Use hardware security modules (HSMs) or a secure element in each vehicle to store private keys so certificates cannot be extracted; enforce short-lived certificates with automated rotation and revocation via a certificate revocation list (CRL) or OCSP.
Enforce phishing-resistant MFA (FIDO2/hardware tokens) for personnel, add adaptive risk-based authentication (device	Spoofing	Enforce phishing-resistant MFA (FIDO2/hardware tokens) for personnel, add adaptive risk-based authentication (device

fingerprinting, geo-velocity checks), and invalidate sessions on anomalous behavior.		fingerprinting, geo-velocity checks), and invalidate sessions on anomalous behavior.
Authentication service overwhelmed by credential stuffing	Denial of Service	Deploy Web Application Firewall (WAF) rules and CAPTCHA/behavioral challenges on login, implement progressive account lockout with exponential backoff, and use AWS Shield/rate-based rules to absorb volumetric traffic.
Service-center account escalates OTA scope	Elevation of Privilege	Enforce fine-grained, vehicle-scoped authorization checks on every OTA request (object-level access control), and require step-up approval for update requests outside a partner's normal fleet assignment.
API probing exposes data beyond scope	Information Disclosure	Enforce strict OAuth scopes mapped to the minimum data a partner needs, apply schema validation and output filtering on every endpoint, and log/alert on abnormal query patterns consistent with reconnaissance.
Telemetry data altered to mask malicious activity	Tampering	Sign telemetry records at the point of capture, use append-only/immutable storage (e.g., write-once object storage with versioning) and integrity hashes to detect unauthorized modification.

(Add or remove table rows as necessary.)

6. Summary and Recommendations

Top Three Most Critical Threats

(List the three most serious threats from your analysis and explain why they are high priority.)

Firmware tampering via a compromised signing key (Tampering) — This threat directly matches the firmware version mismatches AutoDrive has already detected. Because OTA updates control safety-critical vehicle code, a successful attack here could impact vehicle safety at fleet scale, not just a single system. It is rated Critical despite moderate likelihood because the potential impact is severe and irreversible once deployed.

Credential stuffing leading to MFA bypass and account takeover (Spoofing) — AutoDrive has already observed failed-login patterns consistent with credential stuffing. Combined with a session-hijacking bypass of MFA, this gives an attacker a foothold to reach downstream systems (telemetry, OTA triggers), making it both highly likely and high impact.

API reconnaissance leading to information disclosure (Information Disclosure) — The irregular API traffic already logged by AutoDrive suggests active probing. Because the API sits at a trust boundary shared with external partners, a successful exploit could expose sensitive diagnostics or security logs at scale with relatively low attacker effort, making this both likely and high impact.

Final Recommendations for Improving Security

(Summarize key recommendations to enhance system security and reduce risks.)

Harden cryptographic key management for firmware signing: move to HSM-backed, dual-control signing and enforce fail-closed signature verification on every vehicle.

Strengthen authentication resilience: adopt phishing-resistant MFA, adaptive risk-based login controls, and WAF/rate-limiting to blunt credential-stuffing and brute-force activity.

Apply least-privilege and zero-trust principles across the API layer: enforce fine-grained OAuth scopes, per-request authorization checks, and continuous automated testing for broken access control.

Improve observability and non-repudiation: deploy centralized, tamper-evident logging for authentication events, OTA actions, and API calls so that every sensitive action is attributable and auditable.

Reduce blast radius through segmentation: apply least-privilege IAM policies and default-deny configurations to telemetry storage, and regularly audit for misconfigurations that could lead to data leakage.

Institutionalize the process: incorporate this STRIDE analysis into a recurring threat-modeling cadence aligned with ISO/SAE 21434, revisiting it whenever new features, partners, or components are added to the platform.